

Windows Kullanıcı ve Grup Yapısı

Windows'ta yerel kullanıcı ve gruplar Local Users and Groups üzerinden yönetilir. Kullanıcı ve grup bilgileri SAM (Security Account Manager) veritabanında tutulur.

- **Users:** Standart kullanıcıların bulunduğu, sınırlı yetkilere sahip gruptur.
- **Administrators:** Yönetici yetkilerine sahip kullanıcıların bulunduğu gruptur.
- **Administrator:** Yerleşik yönetici hesabıdır.
- **Guest:** Sınırlı yetkili yerleşik misafir hesabıdır ve genellikle devre dışıdır.
- **UAC (User Account Control):** Yönetici yetkisi gerektiren işlemlerde ek onay mekanizması sağlar.

Bir kullanıcı Administrators grubuna eklenerek yönetici yetkilerine sahip olabilir.

SID (Security Identifier)

Windows'ta kullanıcı ve grupları tanımlamak için SID (Security Identifier) kullanılır. Kullanıcı adı değiştirilebilse de SID hesabın kendisine özgü olduğundan değişmez.

- Olay kayıtlarında kullanıcı adı yerine veya kullanıcı adıyla birlikte SID görülebilir.
- Aynı kullanıcı adının farklı bir hesaba ait olup olmadığını ayırt etmede kullanılır.
- Hesap adı değiştirildiğinde geçmiş ve mevcut olay kayıtlarını aynı hesapla ilişkilendirmek için önemlidir.
- Analiz sırasında hesabın gerçek kimliğini takip etmeyi kolaylaştırır.

Analist açısından SID; geçmiş ve güncel olayları aynı hesapla ilişkilendirmek, hesap adı değişikliklerini takip etmek ve farklı hesapları birbirinden ayırt etmek için önemlidir.

UAC (User Account Control)

UAC, Windows'ta yönetici yetkisi gerektiren işlemlerde kullanıcıdan onay alınmasını sağlayan güvenlik mekanizmasıdır.

- Standart kullanıcıların yetkilerini gereksiz yere yükseltmesini engeller.
- Yönetici yetkisi gerektiren bir program "Yönetici olarak çalıştır" seçeneğiyle çalıştırıldığında yükseltilmiş yetkilerle çalışır.
- Linux'taki sudo gibi, yönetici yetkisi gerektiren işlemlerin kontrollü şekilde gerçekleştirilmesini sağlar.
- sudo komut bazında yetki yükseltirken, UAC Windows'ta uygulamanın yükseltilmiş yetkiyle çalıştırılmasını onaylatır.

Event Viewer ve Olay Kayıtları

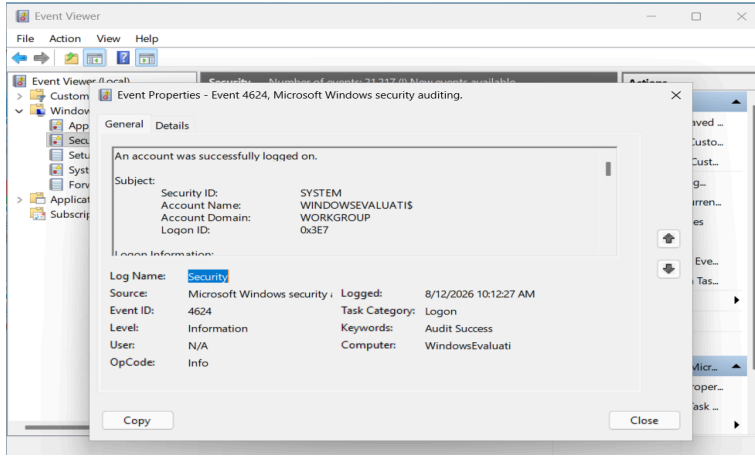
Windows'ta olay kayıtları Event Viewer üzerinden görüntülenir. Temel günlükler:

- **Application:** Uygulamalarla ilgili olayları ve hataları kaydeder.
- **Security:** Oturum açma, oturum kapatma, hesap ve yetki işlemleri gibi güvenlik olaylarını kaydeder.
- **System:** İşletim sistemi, sürücüler ve sistem bileşenleriyle ilgili olayları kaydeder.
- **Setup:** Windows kurulumu ve güncelleştirme işlemleriyle ilgili olayları kaydeder.

Windows'ta olaylar yapılandırılmış bir şekilde tutulur. Her olayın bir Event ID'si ve çeşitli alanları bulunur. Bu yapı, belirli olayların filtrelenmesini ve aranmasını kolaylaştırır.

Bir olay kaydında temel olarak Event ID, Source, Level, tarih-saat, User, Computer ve Details alanları incelenir.

Linux logları çoğunlukla metin tabanlı olduğundan farklı biçimlerdeki kayıtları yorumlamak gerekebilir. Windows'un yapılandırılmış olay yapısı belirli olayları aramayı kolaylaştırırken, beklenmeyen veya daha önce tanımlanmamış durumların fark edilmesi yine analistin olayları doğru yorumlamasına bağlıdır.



Önemli Windows Event ID'leri

- **4624** → Başarılı oturum açma. Başarılı bir kullanıcı girişini gösterir. Beklenmeyen saatlerde veya alışılmadık Logon Type ile gerçekleşmesi şüpheli olabilir.
- **4625** → Başarısız oturum açma. Yanlış parola veya geçersiz kimlik bilgileri nedeniyle gerçekleşen giriş denemesidir. Çok sayıda tekrarlanması brute-force denemelerine işaret edebilir.
- **4634** → Oturum kapatma. Bir kullanıcı oturumunun sona erdiğini gösterir.
- **4720** → Yeni kullanıcı hesabı oluşturulması. Sistemde yeni bir kullanıcı hesabı oluşturulduğunu gösterir. Beklenmeyen bir hesap oluşturulması kalıcılık amacıyla şüpheli olabilir.
- **4728 / 4732** → Kullanıcının gruba eklenmesi. Bir hesabın güvenlik grubuna eklendiğini gösterir. Özellikle Administrators gibi ayrıcalıklı gruplara yapılan eklemeler dikkatle incelenmelidir.

- **7045** → Yeni servis kurulması. Sisteme yeni bir Windows servisi kurulduğunu gösterir. Beklenmeyen servisler kötü amaçlı yazılım veya kalıcılık amacıyla kullanılabilir.
- **1102** → Security olay günlüğünün temizlenmesi. Security logunun temizlendiğini gösterir. Saldırganın izlerini silmeye çalışması açısından önemli ve şüpheli bir olaydır.

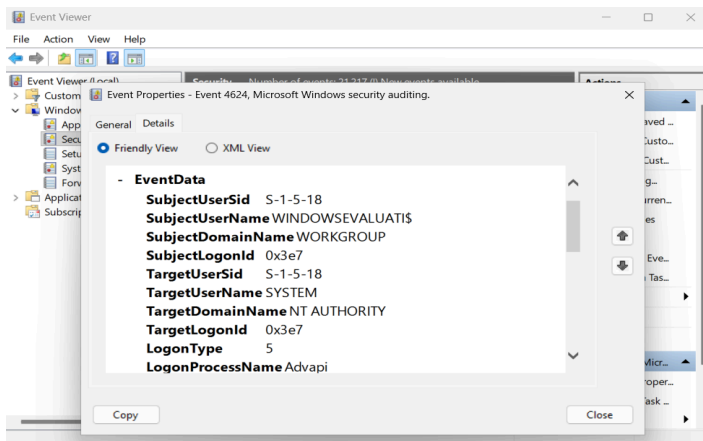
Not: 4728 ve 4732 farklı grup türleri için kullanılır. Administrators gibi yerel gruplarda özellikle 4732 olayı önemlidir.

Oturum Açma Türleri (Logon Type)

Windows'ta Logon Type, bir oturumun sisteme hangi yöntemle açıldığını gösterir. Aynı Event ID farklı Logon Type değerleriyle farklı anlamlara gelebilir.

- **2 – Interactive:** Kullanıcının bilgisayarın başında fiziksel olarak oturum açması.
- **3 – Network:** Ağ üzerinden erişim sağlanması.
- **4 – Batch:** Zamanlanmış görev veya benzeri otomatik işlemler.
- **5 – Service:** Bir Windows servisinin kullanıcı hesabıyla çalışması.
- **7 – Unlock:** Kilitli bilgisayarın tekrar açılması.
- **8 – NetworkCleartext:** Kimlik bilgilerinin ağ üzerinden açık metin biçiminde iletildiği oturum.
- **10 – RemoteInteractive:** RDP gibi uzak masaüstü bağlantıları.
- **11 – CachedInteractive:** Domain bağlantısı olmadığında önbelleğe alınmış kimlik bilgileriyle giriş.

Örneğin, gece yarısı gerçekleşen Logon Type 10 (RDP) kullanıcının uzaktan bağlandığını gösterirken, aynı saatteki Logon Type 5 bir servis hesabının çalışması olabilir. Bu nedenle yalnızca Event ID'ye bakmak yerine Logon Type ve diğer alanlar birlikte değerlendirilmelidir.



UYGULAMA:

Başarısız Oturum Açma Denemesi – Event ID 4625

Windows giriş ekranında vboxuser2 hesabıyla bilerek yanlış parola girilerek başarısız bir oturum açma olayı oluşturuldu. Security günlüğünde olay Event ID 4625 olarak kaydedildi.

Event ID: 4625

Account Name: vboxuser2

Logon Type: 2 (Interactive)

Failure Reason: Unknown user name or bad password

Source Network Address: 127.0.0.1

Computer: WINDOWSEVALUATI...

Logon Type 2 olması, giriş denemesinin bilgisayarın başındaki Windows oturum açma ekranından gerçekleştirildiğini göstermektedir.



Not: Bir olayın Security günlüğünde bulunmaması, olayın gerçekleşmediği anlamına gelmez. Windows'ta hangi güvenlik olaylarının kaydedileceği denetim politikaları (Audit Policy) tarafından belirlenir. Gerekli denetim ayarı etkin değilse gerçekleşen bir olay için log kaydı oluşmayabilir.

Bu nedenle Blue Team analizinde kayıt yok ile olay yok ifadeleri birbirinden ayrılmalıdır. Bir olayın loglarda bulunmaması durumunda, öncelikle ilgili denetim politikasının olayı kaydetmeye izin verip vermediği kontrol edilmelidir.

PowerShell Uygulaması

```
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625} -MaxEvents 5
```

Security günlüğünden Event ID 4625 olan, yani başarısız oturum açma olaylarından en fazla 5 tanesini getiren komut.

Analist açısından, Event Viewer daha çok tek tek kayıtları incelemek, PowerShell ise çok sayıda kaydı hızlıca filtrelemek ve işlem yapmak için uygun.

Kullanıcı Oluşturma ve Yönetici Grubuna Ekleme

Windows'ta yeni bir yerel kullanıcı hesabının oluşturulması. Event ID 4720, yerel bir güvenlik grubuna kullanıcı eklenmesi ise Event ID 4732 ile kaydedilir.

Bir hesabın Administrators grubuna eklenmesi, hesabın yönetici ayrıcalıkları kazanmasına neden olur. Bu nedenle beklenmeyen kullanıcı oluşturma ve ayrıcalıklı gruplara üyelik değişiklikleri, saldırganların kalıcılık ve ayrıcalık yükseltme amacıyla kullanabileceği işlemler açısından önemlidir.

Bir hesabın gerçekten Administrators grubunda olup olmadığı Get-LocalGroupMember -Group "Administrators" komutuyla kontrol edilebilir.

Kriter	Linux	Windows
Başarısız giriş kaydı	auth.log / secure gibi loglarda tutulur	Security logunda tutulur
Olayın belirlenmesi	SSH, PAM vb. üzerinden anlaşılabilir	Event ID 4625 ile başarısız oturum açma olayı doğrudan belirlenebilir
Bilgi miktarı	Tarih, kullanıcı, kaynak IP, servis ve hata bilgileri gibi bilgiler bulunabilir	Kullanıcı, kaynak bilgisayar, IP adresi, oturum açma türü, hata nedeni ve olay kimliği gibi daha ayrıntılı alanlar bulunabilir
Arama / filtreleme	grep, tail, journalctl gibi araçlarla yapılır	Event Viewer filtreleri veya PowerShell ile yapılabilir
Analist açısından	Komut satırı kullanımı hızlı ve esnektir	Yapılandırılmış Event ID ve alanlar sayesinde olayları sınıflandırmak daha kolaydır